

Security+ 2.4 · Physical Attacks

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 2.4 — Physical Attacks (4:04)** ·

[Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Ataque físico: brute force física (cortar cadeado, força porta); RFID cloning (clonar badge NFC); environmental (pular cerca, furar parede). Defesa: mantrap/vestibular control, badge + PIN (2 fatores físico), câmeras, alarmes, monitorar log RFID com alarme de horário incomum.

Highlights que a prova cobra

- RFID cloning com um device de \$500 copia um badge (proximity)
- Defesa física: mantrap, badge com PIN (2-factor), câmeras+alarmes

Dicas de prova & Cenários Típicos

- 'clones an access badge' = RFID cloning

Cenário clássico de exame: Cenário: 'invasor copia o badge de funcionário e entra na sala de servidor' = RFID cloning.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 2.4 — Physical Attacks)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Um atacante usa RFID para clonar crachás de funcionários e acessar áreas restritas. Que tipo de ataque físico é esse?

- A) Tailgating
- B) Shoulder surfing
- C) Clonagem de credenciais
- D) Dumpster diving

2. Sistema-isca que finge ser vulnerável pra atrair e estudar atacantes:

- A)** Honeygot
- B)** DMZ
- C)** Bastion host
- D)** Jump box

3. Cenário corporativo (Physical Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'RFID cloning com um device de \$500 copia um badge (proximity)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: RFID cloning com um device de \$500 copia um badge (proximity)...

4. Cenário corporativo (Physical Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Defesa física: mantrap, badge com PIN (2-factor), câmeras+alarmes'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Defesa física: mantrap, badge com PIN (2-factor), câmeras+alarmes...

5. Cenário corporativo (Physical Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'clones an access badge' = RFID cloning'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'clones an access badge' = RFID cloning...

6. Cenário corporativo (Physical Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'invasor copia o badge de funcionário e entra na sala de servidor' = RFID cloning'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Cenário: 'invasor copia o badge de funcionário e entra na sala de servidor'...

7. Cenário corporativo (Physical Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'RFID cloning com um device de \$500 copia um badge (proximity)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: RFID cloning com um device de \$500 copia um badge (proximity)...

8. Cenário corporativo (Physical Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Defesa física: mantrap, badge com PIN (2-factor), câmeras+alarmes'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Defesa física: mantrap, badge com PIN (2-factor), câmeras+alarmes...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Physical Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'clones an access badge' = RFID cloning'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'clones an access badge' = RFID cloning...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Physical Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'invasor copia o badge de funcionário e entra na sala de servidor' = RFID cloning.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Cenário: 'invasor copia o badge de funcionário e entra na sala de servidor'...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) C — Clonagem de credenciais.

✓ **Por que está certa:** A alternativa correta é 'Clonagem de credenciais'. A clonagem de credenciais ocorre quando um atacante copia os dados de um cartão de acesso (como crachás RFID ou cartões de proximidade) para outro dispositivo, permitindo acesso não autorizado. No cenário, o uso de RFID para copiar o sinal do crachá e replicá-lo em um cartão virgem é um exemplo clássico de clonagem de credenciais físicas. A CompTIA Security+ aborda ataques físicos e contramedidas, como o uso de cartões com criptografia ou autenticação mútua para prevenir clonagem.

✗ **Por que as outras estão erradas:**

- *Tailgating:* Tailgating é a prática de seguir fisicamente uma pessoa autorizada através de uma porta segura sem usar credenciais próprias. Não envolve clonagem de cartões ou RFID; é uma intrusão física passiva. A alternativa é incorreta porque o enunciado descreve a cópia eletrônica de credenciais, não a entrada por proximidade.
- *Shoulder surfing:* Shoulder surfing é a observação direta por cima do ombro para obter informações como senhas ou PINs. Não envolve RFID ou clonagem de crachás. A alternativa é incorreta porque é uma técnica de observação visual, não de duplicação eletrônica.
- *Dumpster diving:* Dumpster diving é a busca em lixeiras por informações descartadas (documentos, mídias) que possam ser úteis ao atacante. Não tem relação com RFID ou clonagem de credenciais. A alternativa é incorreta porque se trata de recuperação de dados descartados, não de interceptação e cópia de sinais de cartão.

2) A — Honeypot.

✓ **Por que está certa:** Honeypot é um sistema-isca projetado para parecer vulnerável e atrair atacantes, com o objetivo de estudar suas táticas, técnicas e procedimentos (TTPs), desviar atenção de sistemas reais e coletar inteligência sobre ameaças. Pode ser de baixa interação (simula serviços) ou alta interação (sistema real isolado). É um controle de segurança proativo e de detecção, conforme o objetivo SY0-701 3.2 (implementação de segurança) e 4.8 (monitoramento e detecção). A questão descreve exatamente um sistema-isca que finge ser vulnerável para atrair e estudar atacantes, que é a definição de honeypot.

✗ **Por que as outras estão erradas:**

- *DMZ:* DMZ (Zona Desmilitarizada) é uma sub-rede física ou lógica que fica entre a rede interna confiável e a rede externa não confiável (ex.: Internet). Ela hospeda serviços públicos (web, e-mail, DNS) para evitar que ataques externos alcancem diretamente a rede interna. A DMZ não é um sistema-isca; é um segmento de rede projetado para expor serviços controladamente. Não finge ser vulnerável nem tem como objetivo atrair e estudar atacantes. A questão pede um sistema-isca, não uma arquitetura de segmentação.
- *Bastion host:* Bastion host é um sistema fortemente protegido e exposto a uma rede não confiável, geralmente atuando como ponto de entrada único para administração remota ou como proxy. Ele é endurecido (hardened) e monitorado, mas não é uma isca; é um ponto de defesa. Seu propósito é ser seguro, não parecer vulnerável. A questão descreve um sistema que finge ser vulnerável para atrair atacantes, o que é o oposto do bastion host, que é projetado para ser o mais seguro possível.
- *Jump box:* Jump box (ou jump server) é um sistema intermediário usado para acessar e administrar dispositivos em uma rede segregada, como uma DMZ ou rede interna. Ele centraliza o acesso administrativo, aplica autenticação forte e registra atividades. Não é uma isca; é uma

ferramenta de controle de acesso. Não finge ser vulnerável nem tem como objetivo estudar atacantes. A questão pede um sistema-isca, não um ponto de salto administrativo.

3) D — Implementar a solução correspondente: RFID cloning com um device de \$500 copia um badge (proximity)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Physical Attacks): RFID cloning com um device de \$500 copia um badge (proximity).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) D — Implementar a solução correspondente: Defesa física: mantrap, badge com PIN (2-factor), câmeras+alarmes....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Physical Attacks): Defesa física: mantrap, badge com PIN (2-factor), câmeras+alarmes.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) D — Implementar a solução correspondente: 'clones an access badge' = RFID cloning....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Physical Attacks): 'clones an access badge' = RFID cloning.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) D — Implementar a solução correspondente: Cenário: 'invasor copia o badge de funcionário e entra na sala de servidor'....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Physical Attacks): Cenário: 'invasor copia o badge de funcionário e entra na sala de servidor' = RFID cloning..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) D — Implementar a solução correspondente: RFID cloning com um device de \$500 copia um badge (proximity)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Physical Attacks): RFID cloning com um device de \$500 copia um badge (proximity).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) C — Implementar a solução correspondente: Defesa física: mantrap, badge com PIN (2-factor), câmeras+alarmes....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Physical Attacks): Defesa física: mantrap, badge com PIN (2-factor), câmeras+alarmes.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) C — Implementar a solução correspondente: 'clones an access badge' = RFID cloning....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Physical Attacks): 'clones an access badge' = RFID cloning.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) A — Implementar a solução correspondente: Cenário: 'invasor copia o badge de funcionário e entra na sala de servidor'....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Physical Attacks): Cenário: 'invasor copia o badge de funcionário e entra na sala de servidor' = RFID cloning..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.